

AEGISTWIN

Spotting account takeover by recognising the human

A working, explainable defence for Nigerian app, USSD and agency banking

HELD-OUT RECALL

90.9%

40/44 challenged

FALSE-POSITIVE RATE

0.037%

2/5356 normal

END-TO-END P99

65 ms

100 warm full-API calls

Executive summary

PINs and OTPs prove knowledge, not presence. AegisTwin maintains a server-side behavioural twin for each account, compares a live transaction with that person's established habits, and fuses the result with a calibrated population model. It then chooses the least disruptive reversible response and explains it in one plain sentence.

Core claim: at the challenge threshold, AegisTwin caught 40 of 44 held-out takeovers while challenging 2 of 5,356 normal sessions.

What makes the prototype differentiated

- Two-sided network intelligence: a Mule Graph catches many-sender/rapid-cash-out behaviour; analyst-confirmed recipient reputation propagates across accounts with decay and a two-victim hard-floor rule.
- Agent-Terminal Integrity Twin: gateway-attested cross-customer patterns expose one compromised agency endpoint, while a compound guard protects legitimate high-throughput agents.
- Decision Confidence Envelope: risk and certainty are separate; thin history, missing evidence and scorer disagreement are surfaced instead of disguised as a safe score.
- Cross-Channel + Calendar Twins: unusual app-to-USSD enrolment sequences raise takeover risk, while three-cycle monthly payments reduce needless friction.
- Coercion + trajectory defence: consented in-call safety signals can privately pause payment; recovery/auth/SIM precursors create a decaying account risk window.
- Personalised friction and recourse: policy compares fraud exposure with customer cost, respects a Regret Budget, and returns safe, non-gameable clearance routes.
- Adaptive attacker: 2,688 valid raw-event variants expose a NGN 48,000 evasion and test recipient/precursor mitigations without self-training on the answer.
- AegisMesh + outage assurance: signed rotating cross-bank sketches share patterns, not records; local-action ceilings, revocation, signed cache, no-settlement receipt and hash-chained recovery constrain harm.

Challenge fit

Required element	Delivered
Synthetic sessions	30,000 scored sessions, 750 personas, eight attack families, 12 hard-legitimate families, delayed feedback and causal precursors.
Live model	FastAPI service; server-built features; calibrated Random Forest + transparent personal anomaly scorer + policy fusion.
Both error sides	Recall, precision, false-positive rate, TP/FP/FN, cohort results, rare-prevalence projection and known failures.
Plain explanation	One customer-ready sentence plus safe channel, clearance action and expected timing for every interruption.
USSD / feature phone	Gateway timing/menu path, bank history, recipient graph and optional attested telco signals; no app sensor dependency.
Power / network cuts	Working four-state outage controller; degraded confidence, isolated no-settlement handling, tamper detection and idempotent reconciliation.
Agency / consortium	Attested terminal risk plus signed private recipient/terminal/campaign sketches; one bank or uncorroborated evidence only monitors.

02 System and AI design

A hybrid decision is stronger than either a black-box model or a fixed rule list alone.

1 · Event	2 · Sender twin	3 · Other risk views	4 · AI + policy	5 · Evidence
App / USSD / agent	Sender behavioural twin	Graph + agent + AegisMesh	Hybrid AI + cost policy	Recourse + audit hash

Signals and trust boundaries

Signal family	Examples	How trust is constrained
Transaction	amount/MAD, balance drain, recipient novelty, velocity, hour	Computed inside the bank from earlier events; client cannot supply its baseline.
App behaviour	typing, handling, navigation, coercion-safety telemetry	Optional; coercion fields are zeroed unless consented and device-attested.
USSD behaviour	menu depth, interaction speed, path signature, SIM/IP	Collected by gateway/core systems, usable on feature phones.
Telco lifecycle	activation age, IMSI/ICCID change flags, swaps/30d, OTP proximity	Ignored unless gateway-attested; accepts bounded indicators, not raw subscriber IDs.
Account + recipient	failed auth, recovery, mule fan-in/cash-out, verified change	Precursor hazard decays; mule floor requires cash-out, not merchant fan-in alone.
Agent terminal	customer diversity, recipient concentration, auth failures, location/shift	Ignored unless gateway-attested; one victim only monitors, three independent victims quarantine.
Exchange + policy	rotating sketch, issuer count, confidence, action costs	Signed banks share no raw record; without local corroboration the exchange can only monitor.

Decision mechanics

The population model learns attack combinations; personal, recipient and agent-terminal scorers expose accountable deviations. Ordered channel transitions, calendar rhythm and a decaying precursor window add sequence and time. AegisMesh adds delayed cross-bank evidence after the model, never as a leaked training label. Risk fusion is followed by separate confidence and a friction-cost policy. Shared evidence alone can monitor; locally corroborated evidence can contribute a delay but not a hold.

Adaptive result: NGN 48,000 evasion scores 0.293; recipient graph raises the same event to 0.760 and a reversible delay.

Live proof: cross-channel sequence 0.720; a three-cycle payment remains 0.074. AegisMesh moves a baseline 0.084 to one-bank monitoring 0.373; two uncorroborated banks cap at 0.420, while local corroboration selects a reversible delay at 0.726.

Outage proof: three events were hash-chained; deliberate tampering was detected; all 3 events re-scored after recovery with 0 duplicate actions and 0 automatic settlements. Detection 2.8 ms; recovery 74.5 ms on the test laptop.

Agent proof: a busy legitimate terminal remains at 0.084; a compromised cross-customer terminal reaches 0.740 and a reversible delay. Three independent victims quarantine it; an unattested forged claim contributes 0% agent evidence.

Why it remains explainable

- The API returns model/anomaly/fused risk, a separate decision-confidence score and reasons, profile/evidence coverage, recipient status, action costs and uncertainty note.
- Customer wording avoids hidden technical claims; structured recourse offers registered-device confirmation, official callback or safe expiry without disclosing thresholds.
- If the model artifact is missing or has a mismatched feature schema, runtime falls back to transparent scoring rather than crashing or accepting blindly.

Operational flow

Risk	Customer treatment	Safeguard
Low	Allow	Current event waits in learning quarantine
Guarded	Allow + monitor	No payment interruption
Elevated	Trusted-channel confirmation	Do not use the possibly compromised channel
High	15-minute settlement delay	Customer can confirm/cancel; reversible
Critical	Two-hour hold + review	Analyst review; SHA-256 chained evidence
Coercion	Private 15-minute safety pause	End calls/screen share; confirm through an official channel
Outage	Monitor / confirm / pending	Never treat missing evidence as safe; never claim isolated settlement

03 Synthetic data, evaluation and failure cases

The test is chronological and the numbers describe the exact final fusion policy.

How the dataset was generated

A deterministic generator (seed 2026) creates 750 personas across six Nigerian cities. After eight earlier events, accounts may receive one of eight attacks or 12 hard legitimate changes. It includes groomed-recipient takeovers plus legitimate recovery, failed-login retry, cooperative networks, mule cash-out, shared agents, monthly cycles and delayed confirmations. Post-label reputation and event-type shortcuts are excluded from population-model training. The newest 18% is held out.

Final held-out results

Live threshold	Recall	Precision	FPR	TP / FP / FN
Monitor or stronger	93.2%	85.4%	0.131%	41 / 7 / 3
Customer confirmation or stronger	90.9%	95.2%	0.037%	40 / 2 / 4
Settlement delay or hold	90.9%	95.2%	0.037%	40 / 2 / 4
Two-hour hold and review	79.5%	97.2%	0.019%	35 / 1 / 9

Held-out window: 5,400 sessions, 44 takeovers (0.81%); model/fused ROC-AUC 0.9729/0.9611, neither perfect. The best single feature is 0.9385. At 0.1% prevalence, the measured confirmation rates project 3.73 false alerts per 10,000; this is a mathematical projection, not field validation.

Channel and scenario evidence

Cohort	Held-out evidence	Result at ≥0.48
USSD	2,320 sessions / 21 takeovers	95% recall; 0.000% FPR
App	2,346 sessions / 15 takeovers	87% recall; 0.000% FPR
Agent	734 sessions / 8 takeovers	88% recall; 0.276% FPR
Unseen accounts	150 accounts / 42 takeovers	83% recall; 0.101% FPR
Busy agent	60 legitimate events	0% challenged
Community cooperative	56 legitimate events	0% challenged

Known failures—shown, not hidden

- Low-and-slow recall is 0% (0/3); remote-control USSD recall is 75%. These deliberately subtle misses replace the previous unrealistic perfect ranking.
- Account-disjoint confirmation recall falls to 83.3% with 0 customer overlap, showing the cost of generalising beyond established twins.
- Emergency transfers are the principal hard-negative cohort: 3.23% (2/62) were challenged. Every action remains reversible.
- Adaptive search found a same-device/SIM/IP NGN 48,000 evasion at 0.293. A fresh recipient without graph or precursor evidence remains a disclosed weakness.

04 Security, deployment and reproducibility

A prototype judges can run today, with explicit gates before any real-money use.

Security and privacy controls

Risk	Implemented control	Production next step
Forged client baselines	All behavioural profiles computed server-side	Authenticated event bus + schema registry
Forged telco claims	Unattested envelope is zeroed	mTLS, signed claims, issuer allow-list, key rotation
Forged / accused agent terminal	Unattested evidence ignored; 1 victim monitors, 3 quarantine	Gateway signatures, appeal/reinstatement SLA and cohort calibration
Poisoning	24h quarantine; fraud revokes event and rebuilds profile	Durable scheduler and labelled shadow-mode review
Bad feedback	Independent second approval; appeals; 90-day decay	Identity provider, reason-quality QA and appeal SLA
Replay / tampering	Exact causal replay + idempotent lifecycle + signed audit head	WORM anchor, durable queue and HSM keys
Private exchange abuse	Per-bank signature, nonce, rotation, rate, expiry, revocation, action ceiling	VOPRF/PSI, HSM keys and consortium appeal governance
Tenant / role abuse	Tenant-bound queries; integration/analyst/auditor separation	Workload identity, mTLS and central SIEM
Privacy leakage	Synthetic data; coarse/derived signals; no raw IMSI/ICCID	Consent, minimization, retention and access review
Customer harm	Reversible actions + Regret Budget + plain explanation	Bank-specific appeals and emergency handling
Power / network loss	Signed modes + edge capsule + confidence floor + chained journal	mTLS/HSM keys, encrypted replicated log and alternate-site drill
Release configuration	JSON/CSV list parser + checked-in example + clean-package boot test	Secrets manager, deployment admission checks and staged rollout

Reproduce the evidence

Command	Purpose
<code>pip install -e '[dev,dashboard]'</code>	Install local prototype
<code>python scripts/demo_fraud_sketch_exchange.py</code>	Prove signed private propagation, ceilings, outage cache, tamper and revocation
<code>pytest --cov=aegistwin && python scripts/release_smoke_test.py .</code>	Run 53 tests, coverage gate and clean-copy environment/API boot
<code>python scripts/generate_synthetic.py --rows 30000</code>	Regenerate raw sessions and derived features
<code>python scripts/train_model.py && python scripts/evaluate_system.py</code>	Retrain and reproduce held-out policy metrics
<code>python scripts/evaluate_robustness.py</code>	Reject perfect synthetic ranking; reproduce zero-overlap account test
<code>python scripts/adaptive_attack_search.py</code>	Reproduce the 2,688-candidate adversarial search
<code>python scripts/demo_outage_resilience.py && python scripts/demo_agent_terminal.py</code>	Prove outage recovery and agent-terminal safeguards
<code>python scripts/load_test.py --requests 100 --workers 8</code>	Reproduce 100/100 concurrent successes; 965 ms p99

Evidence provenance

Model SHA-256: ec9eef33a16cf415c6f57969... · Training-feature CSV SHA-256: 321ef953e3360c809305249d... · Model version: rf-calibrated-longitudinal-ng-7.0. Full hashes and machine-readable results are included in the package.

External idea review and clean-room boundary

The public sliit-msc-research SIM-swap repository suggested lifecycle categories but was not copied or imported: it had no licence or generator, its file naming and row counts conflicted, roughly 73.9% of rows were labelled fraud, and its README derived labels from the same inputs. AegisTwin independently implements bounded attested concepts and rare longitudinal evaluation; the full source audit is included.

Submission assets and final gate

Included: four-page PDF/DOCX, captioned real-run demo, source ZIP, synthetic data, model, 53 tests, evaluation/robustness/latency/load/adaptive/platform/outage/agent/sketch JSON, CycloneDX SBOM, restore manifest and checksums. The captain must publish the source and replace CODE_LINK.md. Synthetic results must not be represented as bank-field accuracy.

Recommended next pilot: shadow-mode scoring plus a two-bank governed sketch sandbox; calibrate customer cost and privacy leakage before any real-money action.